

ISO/IEC 42001:2023

SISTEMA DE GESTÃO DE IA

Manual Prático do Gerente e Analista Júnior do AIMS

O que este manual faz: Explica como estabelecer, implementar, operar, auditar, certificar e aprimorar um sistema de gestão de IA. Ele detalha as Cláusulas 4 a 10, todos os nove grupos de controle do Anexo A, a avaliação de riscos e impactos, a Declaração de Aplicabilidade, a certificação, as evidências, as ferramentas, as decisões do gestor e o trabalho do analista júnior.

Alberto (AI) Leiva

Primeira edição • julho de 2026

Prefácio

A norma ISO/IEC 42001 auxilia as organizações a governar a IA por meio de um sistema de gestão organizacional abrangente. Ela não certifica que todos os resultados estejam corretos ou que todos os sistemas de IA sejam seguros. Requer liderança, contexto, planejamento baseado em riscos, recursos, controles operacionais, avaliação de desempenho, ações corretivas e melhoria contínua em torno do desenvolvimento, fornecimento ou uso responsável de sistemas de IA.

Este manual explica os conceitos no idioma original e não reproduz a norma protegida por direitos autorais. Obtenha uma cópia autorizada da ISO/IEC 42001:2023 e de quaisquer outras normas utilizadas para implementação ou auditoria. Certificações, leis, obrigações específicas do setor, contratos e riscos técnicos devem ser avaliados considerando o escopo e a realidade da organização.

Nota sobre informações atuais: Verificado em 14 de julho de 2026. A ISO/IEC 42001:2023 permanece como a norma publicada para requisitos de AIMS. A ISO/IEC 42005:2025 fornece orientações para avaliação de impacto de sistemas de IA. A ISO/IEC 42006:2025 adiciona requisitos para organismos que auditam e certificam AIMS. A ISO 19011:2026 é a diretriz atual para auditoria de sistemas de gestão. As normas ISO/IEC 42003 e 42007 permanecem em desenvolvimento e não são consideradas requisitos neste documento.

Como usar este manual

- Líderes e gestores do AIMS: comecem pelos capítulos 1 a 10, 16 a 20 e 29 a 31.
- Implementadores e equipes de GRC: estudem na ordem e utilizem todos os modelos do Capítulo 32.
- Equipes de IA, dados, produto, segurança, privacidade e jurídica: concentre-se nos capítulos 6 a 15 e 20 a 28.
- Auditores internos: concentrem-se nos capítulos 16 a 20 e 29 e, em seguida, pratiquem o laboratório do capítulo 31.
- Analistas juniores: aprendam a intenção da cláusula, produzam evidências, redijam as conclusões e nunca reivindiquem certificação ou autoridade de auditoria que não possuam.

Índice

Este arquivo contém um sumário nativo do Word, além de um guia de capítulos permanente com numeração de páginas.

Prefácio	2
Como usar este manual	2
Índice	3
Guia do Capítulo	7
1. ISO/IEC 42001 e o Sistema de Gestão de IA	8
1.1 O que a certificação não comprova	8
2. Arquitetura AIMS e o Ciclo PDCA (Planejar-Executar-Verificar-Agir)	9
2.1 Integração com sistemas existentes	9
3. Aplicabilidade, Funções Organizacionais e Roteiro de Implementação	10
3.1 Roteiro de implementação	10
4. Cláusula 4: Contexto da Organização	12
4.1 Questões internas e externas	12
4.2 Partes interessadas e requisitos	12
4.3 Declaração de escopo	12
4.4 Processos AIMS	12
5. Cláusula 5: Liderança	13
5.1 Demonstrando liderança	13
5.2 Política de IA	13
5.3 Funções, responsabilidades e autoridades	13
6. Cláusula 6.1: Ações para lidar com riscos e oportunidades	14
6.1 Entradas de planejamento	14
6.1.1 Ações de risco e oportunidade	14
7. Cláusula 6.1.2: Avaliação de Risco de IA	15
7.1 Método de risco	15
8. Cláusula 6.1.3: Tratamento de Riscos de IA e Declaração de Aplicabilidade	16
8.1 Processo de tratamento	16
8.2 Declaração de aplicabilidade dos campos	16
9. Cláusula 6.1.4: Avaliação do Impacto do Sistema de IA	17
9.1 Processo de avaliação de impacto	17
9.2 Avaliação de risco versus avaliação de impacto	17
10. Cláusulas 6.2 e 6.3: Objetivos e Alterações no Planejamento	19

10.1 Registro objetivo	19
10.2 Planejamento de alterações do AIMS	19
11. Cláusula 7.1: Recursos	20
11.1 Decisões sobre recursos	20
12. Cláusulas 7.2–7.4: Competência, Consciência e Comunicação	21
12.1 Competência	21
12.2 Conscientização	21
12.3 Plano de comunicação	21
13. Cláusula 7.5: Informações Documentadas	22
13.1 Ciclo de vida do controle de documentos	22
14. Cláusula 8.1: Planejamento e Controle Operacional	23
14.1 Controle operacional	23
15. Cláusulas 8.2–8.4: Risco Operacional, Tratamento e Avaliação de Impacto	24
15.1 Gatilhos operacionais	24
15.2 Evidências operacionais	24
16. Cláusula 9.1: Monitoramento, Medição, Análise e Avaliação	25
16.1 Projeto de medição	25
17. Cláusula 9.2: Auditoria Interna	26
17.1 Programa de auditoria	26
17.2 Documento de trabalho de auditoria	26
18. Cláusula 9.3: Análise da Gestão	27
18.1 Entradas	27
18.2 Saídas	27
19. Cláusula 10: Não conformidade, ação corretiva e melhoria contínua	28
19.1 Método de ação corretiva	28
20. Anexos A–D e Declaração de Aplicabilidade	29
20.1 Como funcionam os anexos	29
21. Anexo A.2: Políticas relacionadas à IA	30
21.1 Implementação de controle	30
22. Anexo A.3: Organização Interna	31
22.1 Funções e responsabilidades	31
22.2 Relato de preocupações	31
23. Anexo A.4: Recursos para Sistemas de IA	32
23.1 Fluxo de trabalho de documentação de recursos	32

24. Anexo A.5 e ISO/IEC 42005: Avaliação do impacto do sistema de IA	33
24.1 Quatro resultados de controle	33
24.2 Verificações de qualidade da avaliação	33
25. Anexo A.6: Ciclo de Vida do Sistema de IA	34
25.1 Mudança e aposentadoria	34
26. Anexo A.7: Dados para Sistemas de IA	35
26.1 Controles de dados	35
27. Anexo A.8: Informações para as partes interessadas	36
27.1 Pacote de informações	36
27.2 Relatórios externos e incidentes	36
28. Anexos A.9 e A.10: Uso Responsável, Fornecedores e Clientes	38
28.1 Uso responsável	38
28.2 Terceiros e clientes	38
29. Certificação, ISO/IEC 42006:2025 e Preparação para Auditoria	40
29.1 Caminho de certificação	40
29.2 Significado da ISO/IEC 42006:2025	40
29.3 Preparação para auditoria sem teatro	40
30. Ferramentas de código aberto para evidências do AIMS e garantia de IA	41
30.1 MLflow	41
30.2 DVC	41
30.3 OpenLineage	42
30.4 OpenMetadata	42
30.5 Great Expectations	42
30.6 Evidently	42
30.7 Deepchecks	42
30.8 Giskard	43
30.9 Promptfoo	43
30.10 Garak	43
30.11 PyRIT	43
30.12 Inspect AI	43
30.13 Presidio	44
30.14 ModelScan	44
30.15 CycloneDX	44
30.16 Open Policy Agent	44

30.17 DefectDojo	45
30.18 Langfuse	45
31. Manual do Gerente e do Analista Júnior, Laboratório e Entrevistas	46
31.1 Perguntas do gerente	46
31.2 Trabalho de analista júnior	46
31.3 Laboratório fictício	47
31.4 Plano de trinta dias	47
31.5 O que é a ISO/IEC 42001?	47
31.6 O que é um AIMS?	47
31.7 Todos os controles do Anexo A são obrigatórios?	48
31.8 Avaliação de risco versus avaliação de impacto?	48
31.9 Qual é a Declaração de Aplicabilidade?	48
31.10 Estágio 1 versus Estágio 2?	48
31.11 O que é uma não conformidade?	48
31.12 Como as ferramentas comprovam a conformidade?	48
31.13 Como testar uma ação corretiva?	48
31.14 O que caracteriza um bom analista júnior?	48
32. Modelos, Glossário, Índice e Referências Oficiais	49
32.1 Registro de escopo e contexto do AIMS	49
32.2 Risco de IA e registro de tratamento	49
32.3 Declaração de Aplicabilidade	49
32.4 Avaliação do impacto do sistema de IA	49
32.5 Documento de trabalho de auditoria interna	50
32.6 Registro de revisão gerencial	50
32.7 Glossário	50
32.8 Índice de assuntos	51
32.9 Referências oficiais	51

Guia do Capítulo

Capítulo	Título	Começa na página
1	ISO/IEC 42001 e o Sistema de Gestão de IA	5
2	Arquitetura AIMS e o Ciclo PDCA (Planejar-Executar-Verificar-Agir)	6
3	Aplicabilidade, funções organizacionais e roteiro de implementação	7
4	Cláusula 4: Contexto da Organização	9
5	Cláusula 5: Liderança	10
6	Cláusula 6.1: Ações para lidar com riscos e oportunidades	11
7	Cláusula 6.1.2: Avaliação de Riscos da IA	12
8	Cláusula 6.1.3: Tratamento de Riscos de IA e Declaração de Aplicabilidade	14
9	Cláusula 6.1.4: Avaliação do Impacto do Sistema de IA	15
10	Cláusulas 6.2 e 6.3: Objetivos e Alterações no Planejamento	17
11	Cláusula 7.1: Recursos	18
12	Cláusulas 7.2–7.4: Competência, Consciência e Comunicação	19
13	Cláusula 7.5: Informações Documentadas	20
14	Cláusula 8.1: Planejamento e Controle Operacional	21
15	Cláusulas 8.2–8.4: Risco Operacional, Tratamento e Avaliação de Impacto	22
16	Cláusula 9.1: Monitoramento, Medição, Análise e Avaliação	23
17	Cláusula 9.2: Auditoria Interna	24
18	Cláusula 9.3: Revisão da Gestão	26
19	Cláusula 10: Não conformidade, ação corretiva e melhoria contínua	27
20	Anexos A–D e Declaração de Aplicabilidade	28
21	Anexo A.2: Políticas relacionadas à IA	29
22	Anexo A.3: Organização Interna	30
23	Anexo A.4: Recursos para Sistemas de IA	31
24	Anexo A.5 e ISO/IEC 42005: Avaliação do Impacto do Sistema de IA	32
25	Anexo A.6: Ciclo de Vida do Sistema de IA	33
26	Anexo A.7: Dados para Sistemas de IA	34
27	Anexo A.8: Informações para as partes interessadas	36
28	Anexos A.9 e A.10: Uso Responsável, Fornecedores e Clientes	38
29	Certificação ISO/IEC 42006:2025 e Preparação para Auditoria	40
30	Ferramentas de código aberto para evidências e garantia de IA do AIMS	42
31	Manual do Gerente e do Analista Júnior, Laboratório e Entrevistas	47
32	Modelos, Glossário, Índice e Referências Oficiais	51

1. ISO/IEC 42001 e o Sistema de Gestão de IA

A norma ISO/IEC 42001 especifica os requisitos para que uma organização estabeleça, implemente, mantenha e melhore continuamente um sistema de gestão de IA.

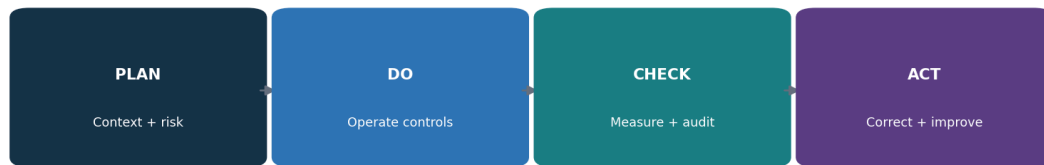
Conceito	Significado literal	Questão de evidência
AIMS	Políticas, objetivos, processos, funções, controles e registros inter-relacionados para IA responsável.	O sistema opera dentro do escopo definido?
Papel da organização	Desenvolvedor/provedor, implementador/usuário, fornecedor, cliente ou várias funções.	Quais responsabilidades são controladas?
sistema de IA	Pessoas, dados, modelos, software, infraestrutura, processos e interfaces utilizados para um resultado de IA	Qual é o limite completo?
Conformidade	Os requisitos são cumpridos dentro do escopo certificado.	Que cláusula, implementação, evidência e resultado sustentam a alegação?
Certificação	Avaliação independente por terceiros do AIMS em conformidade com a norma ISO/IEC 42001	Que entidade, âmbito de aplicação, norma, organismo, datas e estatuto são certificados?

1.1 O que a certificação não comprova

- Isso não garante que todos os resultados da IA sejam precisos, imparciais, seguros, legais, protegidos ou explicáveis.
- A certificação não certifica produtos de IA individualmente, a menos que o escopo e o esquema AIMS do certificado suportem explicitamente essa alegação.
- Não substitui testes de produto, análises jurídicas, avaliações de impacto, controles de privacidade/segurança, validação de domínio ou supervisão humana.
- Isso não transfere a responsabilidade da organização para o organismo de certificação ou fornecedor.

2. Arquitetura AIMS e o Ciclo PDCA (Planejar-Executar-Verificar-Agir)

O AIMS segue a estrutura harmonizada do sistema de gestão e um ciclo contínuo de Planejar-Executar-Verificar-Agir.



The AIMS is a living management system, not a one-time certification project

Figura 1. Ciclo PDCA (Planejar-Executar-Verificar-Agir) do AIMS

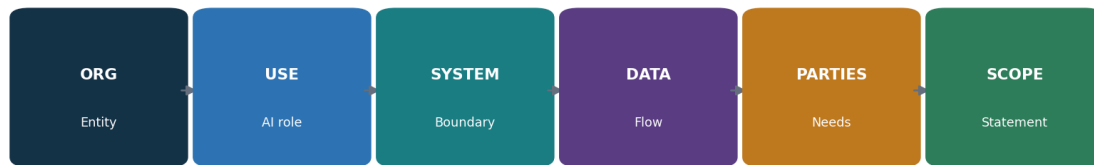
Fase PDCA	Trabalho ISO/IEC 42001	Saída típica
Plano	Contexto, liderança, avaliação de risco/oportunidade, tratamento, objetivos, recursos	Escopo, política, métodos, registro de riscos, processo de impacto, SoA, objetivos
Fazer	Competência, comunicação, documentação, controles operacionais, avaliações	Procedimentos, registros do sistema, aprovações, fornecedores e evidências do ciclo de vida.
Verificar	Monitoramento, medição, análise, auditoria interna, revisão da gestão	Métricas, avaliação, relatório de auditoria, decisões de revisão
Agir	Não conformidade, correção, causa raiz, ação corretiva, melhoria	Registros de ações, testes de eficácia, riscos/controles/objetivos atualizados.

2.1 Integração com sistemas existentes

- Reutilize os processos de governança, controle de documentos, risco, auditoria, ação corretiva, fornecedores, segurança, privacidade, qualidade e continuidade quando seu escopo e controles forem adequados ao risco da IA.
- Criar adições específicas de IA para avaliação de impacto, ciclo de vida de modelos/dados, uso responsável, transparência, supervisão humana e responsabilidades da cadeia de valor.
- Mantenha uma única fonte de verdade e mapeie-a de acordo com as normas ISO 27001, ISO 9001, privacidade, requisitos legais, NIST AI RMF e obrigações do setor, em vez de duplicar registros.

3. Aplicabilidade, Funções Organizacionais e Roteiro de Implementação

Uma implementação eficaz começa com o controle organizacional, um inventário preciso de IA, funções com responsabilidades definidas e um roteiro passo a passo.



A defensible scope connects organizational control to real AI systems and obligations

Figura 2. Cadeia de construção de escopo

Papel	Responsabilidade principal
Órgão diretivo / executivos	Supervisão, direção, recursos, apetite ao risco, decisões importantes
Líder da AIMS	Sistema de gestão coordenada, desempenho, auditorias, melhoria
Proprietário de sistema de negócios/IA	Objetivo, resultado, processo afetado, risco, aprovação, monitoramento
Modelo/dados/produto/engenharia	Requisitos, projeto, dados, avaliação, implementação, mudança
Segurança/privacidade/questões legais/conformidade/proteção	Requisitos especializados, revisão, desafio, incidentes
Gerente de compras/fornecedores	Due diligence, alocação, contratos, evidências, monitoramento, saída
Auditoria interna	Avaliação independente e objetiva, sem deter os controles.

3.1 Roteiro de implementação

- Autorizar o programa e obter os padrões; definir o objetivo, o patrocinador, os recursos e a governança.
- Inventariar sistemas e funções de IA; realizar análises de contexto e de partes interessadas; elaborar escopo e política.
- Defina risco, impacto, tratamento, Declaração de Aplicabilidade (SoA), objetivos, documentação, competência, comunicação e processos operacionais.
- Implementar o Anexo A e controles adicionais de acordo com o risco; coletar evidências durante a operação real.

- Avaliar o desempenho; realizar auditorias internas e revisões de gestão completas; corrigir não conformidades e verificar a eficácia.
- Selecione um organismo de certificação competente; conclua a Etapa 1 e a Etapa 2; mantenha a vigilância e a melhoria contínua.

4. Cláusula 4: Contexto da Organização

A cláusula 4 estabelece por que o AIMS existe, quem é relevante, o que ele abrange e como seus processos interagem.

4.1 Questões internas e externas

- Estratégia, cultura, governança, apetite ao risco, recursos, competência, maturidade de dados, arquitetura tecnológica, sistemas de gestão existentes e mudança organizacional.
- Legislação, regulamentação, expectativas do setor, contratos, requisitos do cliente, normas, confiança pública, preocupações da sociedade, mercados, fornecedores, ameaças, mudanças tecnológicas/de modelo e questões relacionadas ao clima, quando relevantes para os resultados pretendidos do AIMS.
- Registre por que cada problema é relevante, o responsável, o efeito nos AIMS, a resposta e o fator que desencadeia a revisão.

4.2 Partes interessadas e requisitos

- Identificar pessoas e grupos afetados pela IA, mesmo que não sejam usuários ou clientes diretos.
- Inclua reguladores, clientes, trabalhadores, usuários, titulares de dados, fornecedores, parceiros, comunidades, acionistas, auditores, seguradoras e o público em geral, conforme relevante.
- Separar necessidades/expectativas de obrigações de conformidade vinculativas; registrar autoridade/fonte, sistema/processo, proprietário, evidências e monitoramento de alterações.
- Determine quais requisitos a organização abordará por meio do AIMS.

4.3 Declaração de escopo

Elemento de escopo	Clareza necessária
Organização	Entidades jurídicas, unidades de negócios, locais, funções
papel da IA	Desenvolvedor/provedor, implementador/usuário, serviço/fornecedor, combinação
Produtos/serviços/processos	Ofertas habilitadas por IA e usos internos
Tecnologia e dados	Sistemas, modelos, ambientes, interfaces, conjuntos de dados principais
Limites/dependências	Serviços compartilhados, fornecedores, clientes, exclusões
Justificação	Por que os limites são válidos e não evitam os requisitos aplicáveis.

4.4 Processos AIMS

- Defina o objetivo do processo, entradas, saídas, sequência, interação, responsável, critérios, controles, recursos, registros, medidas, riscos e melhorias.
- Um mapa de processos deve conectar inventário, risco, impacto, tratamento, objetivos, ciclo de vida, dados, fornecedor, uso, monitoramento, incidentes, auditoria, revisão e ação corretiva.

5. Cláusula 5: Liderança

A liderança deve assumir a responsabilidade pelos AIMS, políticas, integração, recursos, comunicação, desempenho e prestação de contas.

5.1 Demonstrando liderança

- Tornar os objetivos do AIMS compatíveis com a estratégia e os compromissos de IA responsável.
- Integrar os requisitos do AIMS aos processos de negócios, produtos, compras, dados, tecnologia, pessoas, riscos e mudanças.
- Disponibilize pessoas competentes, tempo, ferramentas, dados, infraestrutura, orçamento, desafios independentes e autoridade.
- Comunique que a gestão eficaz da IA e a conformidade são importantes, inclusive quando a pressão para entregas entra em conflito com os controles.
- Analisar o desempenho e apoiar as pessoas que contribuem para a melhoria ou que levantam preocupações.
- Garantir que os resultados pretendidos sejam alcançados, em vez de tratar a certificação como o único resultado possível.

5.2 Política de IA

- Declarar o propósito, os princípios, os compromissos com os requisitos aplicáveis, a IA responsável baseada em riscos, os objetivos e a melhoria contínua.
- Adeque-se às funções de IA da organização, ao contexto, à cultura, ao impacto, à legislação, aos produtos e à tolerância ao risco.
- Alinhar as políticas de segurança, privacidade, qualidade, dados, ética, RH, compras, produto, registros, segurança e incidentes.
- Aprovar no nível adequado, comunicar às pessoas relevantes, disponibilizar conforme apropriado e rever após intervalos planejados e alterações substanciais.

5.3 Funções, responsabilidades e autoridades

- Defina a responsabilidade pelos AIMS e pelo reporte de desempenho à alta administração.
- Atribua responsáveis para cada sistema de IA, risco, impacto, fonte de dados, modelo, fornecedor, controle, métrica, incidente, mudança e ação corretiva.
- Defina a autoridade de aprovação e escalonamento; evite conflitos em que a mesma equipe cria, valida, aceita e audita riscos de alto impacto sem o devido questionamento.

6. Cláusula 6.1: Ações para lidar com riscos e oportunidades

O planejamento transforma o contexto em riscos gerenciados, oportunidades, controles, objetivos e mudanças controladas.

6.1 Entradas de planejamento

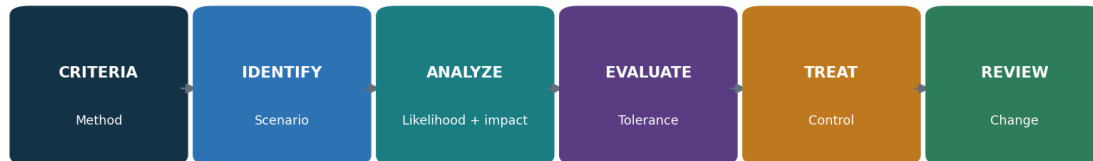
- Contexto e requisitos das partes interessadas; âmbito e processos do AIMS.
- Inventário de IA, funções do sistema, estágio do ciclo de vida, pessoas afetadas, dados, modelos, fornecedores, integrações e condições de uso.
- Benefícios e oportunidades estratégicas, juntamente com ameaças, falhas, danos, incertezas e usos indevidos razoavelmente previsíveis.
- Obrigações legais, regulamentares, contratuais, de segurança, privacidade, proteção, qualidade, registros, acessibilidade, trabalhistas, de propriedade intelectual, do consumidor e setoriais aplicáveis.

6.1.1 Ações de risco e oportunidade

- Planeje ações proporcionais ao impacto nos resultados do AIMS; integre-as aos processos em vez de manter apenas um registro separado.
- Defina ação, responsável, recurso, data, medida, evidência, dependência, decisão residual e avaliação de eficácia.
- As oportunidades podem incluir melhor supervisão, qualidade dos dados, transparência, avaliação, competência, eficiência, confiança das partes interessadas e inovação.
- Impeça que os controles planejados criem novos riscos, como monitoramento excessivo, avisos inacessíveis ou sobrecarga de revisões.

7. Cláusula 6.1.2: Avaliação de Risco de IA

O processo de avaliação de riscos em IA deve utilizar critérios definidos e repetíveis para identificar, analisar, avaliar e priorizar os riscos.



AI risk assessment must be consistent, repeatable, and tied to decisions

Figura 3. Fluxo de trabalho de avaliação de risco de IA

7.1 Método de risco

- Defina o escopo, a unidade de análise, as categorias de risco, as dimensões do impacto, a probabilidade, a gravidade, a escala, a duração, a reversibilidade, os grupos afetados, a incerteza, a agregação, a tolerância e a autoridade de decisão.
- Identificar cenários de risco em relação ao uso pretendido, uso indevido previsível, falha, ataque, dados, modelo, comportamento humano, fornecedores, meio ambiente, legislação e impacto social.
- Analisar o risco inerente e os controles existentes com base em evidências; distinguir o risco atual, o risco alvo e o risco residual.
- Avalie de acordo com critérios; priorize o tratamento com base nas consequências para as pessoas e para o negócio, e não em uma única pontuação técnica.
- Garantir resultados consistentes, válidos e comparáveis, e preservar a avaliação como informação documentada.
- Reavalie em intervalos planejados e após mudanças significativas, incidentes, novos grupos afetados, atualizações de modelos/provedores, desvios, alterações legais ou falhas de controle.

Histórico de risco	Detalhes mínimos
Cenário	Causa/agente, condição vulnerável, evento/ação, comportamento do sistema, parte afetada, consequência
Contexto	Uso, pessoas, geografia, escala, dados, modelo/versão, ferramentas, fornecedor, pressupostos
Análise	Probabilidade, dimensões do impacto, incerteza, evidências, eficácia dos controles existentes
Tratamento	Evitar/reduzir/compartilhar/aceitar, controles, proprietário, data, medida, risco residual
Decisão	Aprovador autorizado, justificativa, condições, validade, monitoramento, gatilho de revisão

8. Cláusula 6.1.3: Tratamento de Riscos de IA e Declaração de Aplicabilidade

O tratamento de riscos seleciona os controles, compara-os com o Anexo A, elabora a Declaração de Aplicabilidade e obtém a aprovação do risco residual.

8.1 Processo de tratamento

- Escolha as opções de tratamento: evitar, alterar/reduzir, compartilhar/transferir, aceitar dentro da autoridade competente ou realizar um projeto-piloto bastante limitado para reduzir a incerteza.
- Determine os controles necessários com base em requisitos legais e contratuais, riscos e impactos da IA, arquitetura, partes interessadas e objetivos.
- Compare os controles selecionados com o Anexo A para verificar se nenhum controle de referência relevante foi omitido.
- Adicionar controles além do Anexo A quando necessário para segurança, privacidade, proteção, qualidade, avaliação técnica, acessibilidade, resiliência ou obrigações setoriais.
- Criar e aprovar um plano de tratamento e obter autorização para risco residual.
- Preservar os resultados e as alterações do tratamento como informações documentadas e controladas.

8.2 Campos de Declaração de Aplicabilidade

Campo	Propósito
Referência/título de controle	Anexo A ou identidade de controle adicional
Aplicável?	Incluído ou excluído do escopo definido do AIMS
Justificação	Risco, obrigação, objetivo, arquitetura ou motivo para exclusão
Implementação	Política/processo/sistema e responsável
Status	Implementado, parcial, planejado, não aplicável
Evidência/teste	Resultados atuais de comprovação e eficácia operacional
Dependências/lacunas	Controles e conclusões sobre fornecedores/clientes/compartilhados
Análise	Gatilhos de revisão e alteração de última/próxima revisão

Aviso da Declaração de Aplicabilidade (SoA): A Declaração de Aplicabilidade não é uma lista de verificação copiada. Ela deve estar em conformidade com o escopo atual, as avaliações de risco e impacto, o plano de tratamento, a implementação real, as evidências e as decisões de risco.

9. Cláusula 6.1.4: Avaliação do Impacto do Sistema de IA

A avaliação do impacto de um sistema de IA examina como um sistema de IA pode afetar indivíduos, grupos e a sociedade ao longo de seu ciclo de vida.



Impact assessment examines effects on people, groups, and society across the life cycle

Figura 4. Avaliação do impacto do sistema de IA

9.1 Processo de avaliação de impacto

- Defina os gatilhos, o escopo, as funções, a independência, os métodos, o envolvimento das partes afetadas, a aprovação, a retenção, a revisão e a relação com o tratamento e as decisões de risco.
- Descreva a finalidade, os usuários, as pessoas afetadas, as decisões/conteúdo, o grau de automação, as alternativas, os dados, o modelo, os fornecedores, a geografia, a escala, a duração e os usos proibidos/previsíveis.
- Identificar os benefícios pretendidos e os impactos adversos sobre direitos, justiça, privacidade, segurança, saúde, acessibilidade, emprego, finanças, crianças/grupos vulneráveis, meio ambiente, cultura, serviços públicos, democracia e condições socioeconômicas, conforme relevante.
- Considere os impactos diretos, indiretos, cumulativos, retardados, reversíveis/irreversíveis, individuais, grupais e sociais.
- Avalie a probabilidade, a gravidade, a escala, a duração, a reversibilidade, a distribuição, a incerteza e as opiniões das partes afetadas.
- Selecionar medidas de mitigação, supervisão humana, notificações, opções, reparação, monitoramento, limites e critérios de interrupção; obter aprovação responsável.
- Atualize antes de mudanças significativas e após incidentes, reclamações, novas evidências, desvios ou expansão de uso.

9.2 Avaliação de risco versus avaliação de impacto

Avaliação de risco	Avaliação de impacto
Gerencia a incerteza que afeta os objetivos, incluindo os da organização, das pessoas e da sociedade.	Concentra-se especificamente nos potenciais efeitos de um sistema de IA sobre indivíduos, grupos e a sociedade.
É possível agregar o risco de portfólio e de processo	É preciso manter-se conectado ao sistema/uso específico e ao contexto afetado.
Tratamento de rações, controles e aceitação residual	Design, implementação, uso, transparência, supervisão, reparação e monitoramento de feeds.
Ambos devem trocar informações e manter a consistência.	Ambos exigem métodos documentados, evidências, decisões e revisão.

10. Cláusulas 6.2 e 6.3: Objetivos e Alterações no Planejamento

Os objetivos traduzem as decisões políticas e de risco em resultados mensuráveis; as mudanças devem ser planejadas e controladas.

10.1 Registro objetivo

- Objetivo e resultado pretendido, relacionados com a política/risco/requisito e âmbito de aplicação.
- Medida, cálculo, fonte de dados, população, linha de base, alvo, limite, frequência, proprietário, relatório e limitação.
- Ações, recursos, responsabilidades, cronograma, dependências, evidências e método de avaliação.
- Resposta quando o desempenho não atinge a meta; reavaliação quando a métrica cria incentivos prejudiciais.

Exemplo objetivo	Medida melhor
Inventário completo de IA	Sistemas ativos com proprietário, uso, dados/modelo/provedor, nível de risco, avaliação e status validados + sistemas ativos reconciliados
Melhorar a pontualidade das avaliações	Dias médios e de atraso desde a entrada/alteração do material até a decisão aprovada sobre risco e impacto, por nível.
Reforçar a avaliação	Sistemas de alto impacto que atendem a limites de aceitação definidos, semelhantes aos da produção, incluindo visões de subgrupos e de falhas graves.
Melhorar o controle dos fornecedores	Fornecedores críticos de IA com revisão de escopo atual, obrigações contratuais, evidências e lacunas materiais sanadas + fornecedores críticos
Melhorar a remediação	Resultados corrigidos e eficácia retestada dentro da meta baseada em risco, com exceção da idade e do impacto.

10.2 Planejamento das mudanças do AIMS

- Defina o propósito, as consequências, a integridade do AIMS, os recursos, as responsabilidades, o cronograma, a transição, a comunicação, as evidências e o processo de reversão.
- Os fatores desencadeadores incluem escopo, entidade, produto, uso, modelo, dados, fornecedor, legislação, certificação, processo, organização, ferramentas, método de auditoria e objetivos.

11. Cláusula 7.1: Recursos

A organização deve determinar e fornecer os recursos necessários para estabelecer, operar, avaliar e aprimorar o AIMS.

Recurso	Exemplos	Evidências
Pessoas	AIMS, domínio, dados, aprendizado de máquina, produto, segurança, privacidade, jurídico, segurança, auditoria, fatores humanos	Plano de capacidade, funções, competência, independência, carga de trabalho
Dados	Treinamento/validação/teste/produção, rótulos, metadados, direitos, conjuntos de referência	Inventário, linhagem, qualidade, acesso, retenção, proveniência
Ferramentas	Desenvolvimento, anotação, avaliação, monitoramento, segurança, documentação	Inventário aprovado, versões, validação, acesso, suporte
Computação/sistema	Nuvem/local/borda, armazenamento, rede, registro, log, sandbox	Arquitetura, propriedade, capacidade, resiliência, impacto ambiental
Finanças/tempo	Orçamento, custo da avaliação, revisão de fornecedores, envolvimento das partes interessadas, remediação	Planos, aprovações, valores reais, restrições, decisões

11.1 Decisões sobre recursos

- Adeque a quantidade de recursos ao escopo, risco, complexidade do sistema, escala, obrigações legais e pessoas afetadas.
- Separar os processos de desenvolvimento, validação, aprovação e auditoria é suficiente para gerenciar conflitos de interesse.
- Monitore a sobrecarga de revisores, a abrangência da avaliação, as lacunas de dados, os limites dos fornecedores, o vencimento de licenças, a obsolescência do modelo e a dívida técnica.
- Documentar as restrições aceitas e seu efeito sobre os objetivos e o risco residual.

12. Cláusulas 7.2–7.4: Competência, Consciência e Comunicação

Competência, consciência e comunicação tornam as políticas e os controles aplicáveis em decisões reais.

12.1 Competência

- Definir os requisitos de educação, treinamento, habilidades, experiência, independência, comportamento e autoridade por função e nível de risco.
- Avaliar a competência atual; fornecer treinamento, mentoria, prática supervisionada, suporte especializado ou realocação.
- Avaliar a eficácia por meio de observação, revisão do trabalho produzido, exercícios de simulação, testes e resultados — e não apenas pela presença.
- Conservar as evidências e reavaliar após mudanças de função, sistema, risco, legislação, método ou incidente.

12.2 Conscientização

- As pessoas entendem a política, sua contribuição, os benefícios de um melhor desempenho, as consequências da não conformidade, os canais de comunicação e a escalada do problema.
- Os usuários compreendem o uso aprovado/proibido, as restrições de dados, a verificação, a supervisão humana, as limitações, o tratamento de incidentes/reclamações e as condições de interrupção.

12.3 Plano de comunicação

Campo	Pergunta
O que	Política, sistema/uso, limites, impactos, incidentes, resultados, mudanças, deveres
Porquê/público-alvo	Tomador de decisão, trabalhador, usuário, pessoa afetada, cliente, fornecedor, regulador, público
Quando	Ponto de controle do ciclo de vida, intervalo planejado, incidente, reclamação, mudança, gatilho legal
Como	Treinamento, aviso, cartão do sistema, relatório, contrato, painel de controle, reunião, alerta
Proprietário/aprovação	Quem prepara, valida, aprova, entrega e registra?
Opinião	Como são tratadas as dúvidas, a acessibilidade, a compreensão, as preocupações e as correções?

13. Cláusula 7.5: Informações Documentadas

As informações documentadas devem ser suficientemente controladas para serem confiáveis, localizáveis, protegidas, atuais, retidas e utilizáveis.

13.1 Ciclo de vida do controle de documentos

- Criar/identificar: título, proprietário, ID, versão, data, formato, classificação, escopo, sistema/modelo/dados relacionados e aprovação.
- Revisar/aprovar: revisor competente, conflitos, critérios, comentários, decisão e autorização.
- Publicação/uso: público-alvo correto, acesso, treinamento, data de vigência, disponibilidade no ponto de uso e retirada de versões obsoletas.
- Alteração: motivo, requisitos/processos/sistemas afetados, aprovações, histórico de versões, transição e reversão.
- Proteger: confidencialidade, integridade, disponibilidade, privacidade, segurança, backup, recuperação e preservação de evidências.
- Reter/eliminar: período legal/comercial, retenções, arquivamento, exclusão, cópias para fornecedores, dados derivados e verificação.

Registros obrigatórios/importantes	Exemplo
Fundação AIMS	Contexto, partes interessadas, âmbito de aplicação, política, fluxograma do processo, funções
Planejamento	Método/avaliação de risco, tratamento, SoA, processo/registros de impacto, objetivos, mudanças
Operações	Inventário de IA, recursos, ciclo de vida, dados, fornecedor/uso, comunicação, incidentes
Avaliação	Métricas, análise, auditoria interna, revisão da gestão
Melhoria	Não conformidade, correção, causa raiz, ação corretiva, eficácia
Rastreabilidade do sistema	Versões de modelo/dados/solicitações/ferramentas/configurações, aprovações, avaliações, registros, decisões

14. Cláusula 8.1: Planejamento e Controle Operacional

O planejamento operacional traduz os requisitos do AIMS em controles repetíveis para a entrada, projeto, aquisição, implantação, uso, mudança, gerenciamento de incidentes e desativação da IA.

14.1 Controle operacional

- Defina critérios e controles para os processos; execute-os conforme planejado; retenha evidências suficientes para comprovar o desempenho.
- Controlar as alterações planejadas e analisar as alterações não intencionais; reduzir os efeitos adversos.
- Controlar processos, produtos e serviços fornecidos externamente de acordo com o risco e a responsabilidade.
- Utilize níveis de risco e etapas de ciclo de vida para adequar a revisão, a independência, os testes, a aprovação, o monitoramento e a escalação ao impacto.

Portão	Evidências necessárias para a decisão
Admissão	Finalidade, proprietário, função da IA, pessoas afetadas, dados, fornecedor, risco preliminar, verificação de uso proibido
Projetar/adquirir	Requisitos, risco/impacto, arquitetura, recursos, dados, obrigações do fornecedor, controles, testes
Construir/configurar	Versões, linhagem, desenvolvimento seguro, documentação, prontidão para avaliação
Validar	Testes representativos, limiares, falhas, desafio independente, limitações, ação corretiva
Implantar	Aprovação, condições, informações do usuário, supervisão, monitoramento, incidente, reversão, suporte
Operar/alterar	Desempenho, desvios, reclamações, incidentes, mudanças de fornecedores, regressão, reavaliação
Aposentar	Substituição, comunicação usuário/parte, acesso, integrações, dados, modelos, registros, exclusão

15. Cláusulas 8.2–8.4: Risco Operacional, Tratamento e Avaliação de Impacto

A organização deve executar a avaliação de riscos, o tratamento de riscos e a avaliação de impacto em intervalos planejados e sempre que ocorrerem mudanças significativas.

15.1 Gatilhos operacionais

- Sistema de IA novo ou modificado, uso pretendido, população afetada, geografia, escala, automação, autoridade de decisão, modelo, dados, solicitação, ferramenta, integração, fornecedor ou infraestrutura.
- Nova lei, contrato, incidente, reclamação, constatação de auditoria, vulnerabilidade, inteligência de ameaças, preocupação com a segurança, desvio, falha de avaliação, impacto inesperado ou notificação do fornecedor.
- Alterações nos critérios de risco, objetivos, controles, monitoramento, responsabilidade organizacional, escopo da certificação ou capacidade de recursos.

15.2 Evidências operacionais

- A avaliação aprovada atual está vinculada à versão exata do sistema/modelo/dados/configuração/uso.
- O plano de tratamento e a Declaração de Aplicabilidade (SoA) estão de acordo com os controles implementados, as lacunas, as exceções, a aprovação residual e o monitoramento.
- A avaliação de impacto inclui as partes afetadas, os efeitos diretos/indiretos e sociais, as medidas de mitigação, a reparação e os fatores que desencadeiam a revisão.
- As ações são integradas aos fluxos de trabalho de produto, dados, segurança, privacidade, fornecedor, usuário, incidente e mudança.
- Os resultados e as alterações são mantidos como informações documentadas e controladas.

16. Cláusula 9.1: Monitoramento, Medição, Análise e Avaliação

A avaliação de desempenho determina se o AIMS e seus controles alcançam os resultados pretendidos.

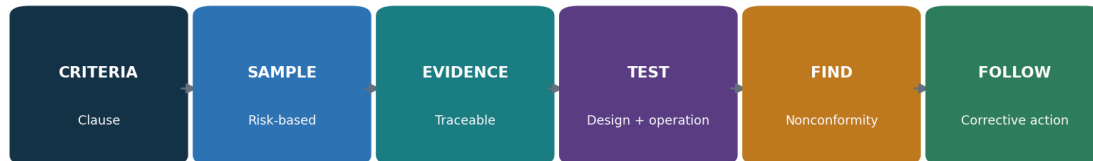
16.1 Projeto de medição

- Defina o que monitorar/medir, os métodos, o cronograma, a responsabilidade, os critérios de aceitação, a análise, a avaliação, a elaboração de relatórios e a retenção dos dados.
- Verificar as fontes de dados, definições, populações, integridade, precisão, tempo, acesso, transformações e limitações.
- Utilize indicadores antecedentes e consequentes em governança, risco, impacto, ciclo de vida, dados, fornecedores, uso, reclamações, incidentes, auditoria e melhoria.
- Evite médias que ocultem falhas graves ou efeitos de subgrupos; combine evidências quantitativas e qualitativas.
- Avaliar tendências e causas, comparar com os objetivos e tomar decisões/fazer ações quando as metas não forem atingidas.

Medida AIMS	Decisão habilitada
Cobertura de inventário/controle	Lacunas desconhecidas ou não identificadas na utilização e avaliação da IA
Cobertura de risco/impacto por idade e mudança	Se as decisões permanecem válidas após mudanças no sistema/contexto.
Resultados da avaliação	Liberação, restrição, reformulação, reversão ou supervisão adicional.
Reclamações/incidentes/reclamações	Impacto nas pessoas, recorrência, comunicação e ação corretiva
Alterações/comprovativos de fornecedores	Reavaliação, ação contratual, alternativa ou saída.
Análise de envelhecimento de auditorias/não conformidades	Controle de pontos fracos, causa raiz, recursos e atenção da gestão.

17. Cláusula 9.2: Auditoria Interna

A auditoria interna fornece evidências independentes, baseadas em riscos, de que o AIMS está em conformidade e opera de forma eficaz.



AIMS audit conclusions require criteria, evidence, judgment, and follow-up

Figura 5. Cadeia de auditoria AIMS

17.1 Programa de auditoria

- Definir objetivos, escopo, frequência, métodos, responsabilidades, planejamento, critérios, relatórios, acompanhamento, recursos, riscos e registros.
- Priorize sistemas de alto impacto, novos modelos/usos, controles deficientes, incidentes, reclamações, mudanças, fornecedores, descobertas anteriores e evidências obsoletas.
- Selecione auditores com base em competência em sistemas de gestão e no domínio da IA, objetividade, confidencialidade, comunicação e independência.
- Utilize entrevistas, revisão de documentos, observação, rastreamento, análise de dados, amostragem, repetição e demonstração técnica segura.
- Reportar os resultados à gestão competente e garantir a correção/ação corretiva e o acompanhamento da sua eficácia.

17.2 Documento de trabalho de auditoria

Campo	Exemplo
Crítérios	Cláusula/controle exato, procedimento interno, lei/contrato, conforme aplicável.
Escopo/exemplo	Processo, sistema/versão de IA, período, população, justificativa da seleção
Evidências	Fonte, proprietário, data, versão, consulta, observação, confiabilidade
Teste/resultado	Projeto e operação, esperado versus observado, exceções
Conclusão	Conformidade, oportunidade, observação ou não conformidade com base objetiva
Seguir	Correção, causa raiz, ação corretiva, responsável/data, eficácia

18. Cláusula 9.3: Revisão da Gestão

A revisão da gestão garante que a alta administração avalie a adequação, a suficiência, a eficácia, a direção, os recursos e as melhorias.

18.1 Entradas

- Status das ações decorrentes de revisões anteriores e alterações em questões internas/externas ou requisitos de partes interessadas.
- Desempenho e tendências do AIMS: objetivos, não conformidades/ações corretivas, monitoramento/medição, auditorias internas e garantia externa relevante.
- Resultados da avaliação de riscos e impactos, status do tratamento, alterações na SoA, incidentes, reclamações, preocupações, reparação, alterações de fornecedores e legais.
- Adequação de recursos, competência, independência, infraestrutura, dados, ferramentas e orçamento.
- Oportunidades para melhoria contínua e alinhamento estratégico.

18.2 Saídas

- Decisões e ações relativas a melhorias, alterações no âmbito/política/objetivos/processos/controles do AIMS, necessidades de recursos, decisões sobre riscos e direção estratégica.
- Para cada ação: justificativa, responsável, prazo, recursos, resultado esperado, métrica, dependência, escalonamento e acompanhamento.
- Conservar a agenda, os materiais, os participantes/autoridades, a discussão, as decisões, as divergências/preocupações, as ações e as evidências de encerramento.

Evite a revisão por slides: a análise gerencial é um processo decisório. Uma apresentação em painel sem questionamentos, decisões sobre riscos, alocação de recursos, ações e acompanhamento constitui evidência fraca.

19. Cláusula 10: Não conformidade, ação corretiva e melhoria contínua

A melhoria corrige problemas, elimina causas, verifica a eficácia e fortalece o AIMS à medida que os riscos e a tecnologia mudam.

19.1 Método de ação corretiva

- Reagir à não conformidade; controlá-la/corrigi-la; abordar as consequências, as pessoas afetadas, as decisões, os dados, os sistemas e as comunicações.
- Avaliar causa e recorrência: revisar as evidências, determinar por que os controles falharam ou foram ignorados e encontrar condições semelhantes em outros locais.
- Implementar ações proporcionais considerando o responsável, a data, os recursos, a proteção provisória, o controle de mudanças e a reavaliação de riscos/impactos.
- Avalie a eficácia utilizando evidências definidas após um período suficiente de operação; não encerre o estudo com base apenas em um novo documento.
- Atualize os riscos, impactos, controles, objetivos, competências, termos do fornecedor, monitoramento, programa de auditoria e informações documentadas conforme necessário.
- Reter a natureza da não conformidade, as ações e os resultados de eficácia.

Resposta fraca	Resposta mais forte
Recapacitar o funcionário	Análise processos, carga de trabalho, incentivos, interfaces, acessos, aprovações e monitoramentos pouco claros; corrija as causas do problema no sistema.
Política de atualização	Alterar fluxo de trabalho/controle, comunicar, treinar, testar operação, monitorar recorrência.
O fornecedor irá resolver o problema.	Acompanhar contrato, mitigação, controle do cliente, prazo, teste, risco residual, alternativa/saída
Encontrando fechado	Correção de evidências, ação corretiva e revisão de eficácia em âmbito semelhante.

20. Anexos A–D e Declaração de Aplicabilidade

O Anexo A é um conjunto de referência de 38 controles em nove grupos; o Anexo B fornece orientações, o Anexo C apresenta ideias sobre objetivos/fontes de risco da IA e o Anexo D apoia o uso setorial/por domínio.

Grupo	Tema	Controles	Foco na implementação
A.2	Políticas relacionadas à IA	3	Política, alinhamento com outras políticas e revisão planejada/orientada por eventos.
A.3	Organização interna	2	Funções e responsabilidades da IA, além de um processo protegido para relatar preocupações.
A.4	Recursos para sistemas de IA	5	Documentar dados, ferramentas, sistemas/computação e recursos humanos ao longo de todo o ciclo de vida.
A.5	Avaliando os impactos dos sistemas de IA	4	Um processo repetível, registros, impactos em pessoas/grupos e impactos sociais.
A.6	ciclo de vida do sistema de IA	9	Objetivos e processos de desenvolvimento responsável, requisitos, registros de projeto, V&V (Verificação e Validação), implantação, operação, documentação técnica e registros de atividades.
A.7	Dados para sistemas de IA	5	Gestão, aquisição, qualidade, proveniência e preparação de dados.
A.8	Informações para os interessados	4	Informações do usuário, relatórios externos, comunicação de incidentes e outras informações das partes interessadas.
A.9	Utilização de sistemas de IA	3	Processo e objetivos de uso responsável, além da adesão ao uso pretendido.
A.10	Relações com terceiros e com clientes	3	Alocação de responsabilidades, governança de fornecedores e obrigações do cliente.

20.1 Como funcionam os anexos

- As cláusulas 4 a 10 contêm os requisitos certificáveis do sistema de gestão.
- O Anexo A fornece objetivos de controle de referência e controles a serem considerados durante o tratamento de riscos; não se trata de uma lista de verificação universal.
- O Anexo B fornece orientações de implementação para os controles do Anexo A, sem adicionar requisitos.
- O Anexo C oferece exemplos de objetivos de IA e fontes de risco que podem apoiar o planejamento e a avaliação.
- O Anexo D explica como o AIMS pode ser utilizado em diferentes domínios e setores.
- A organização pode selecionar controles adicionais; a Declaração de Aplicabilidade (SoA) explica a aplicabilidade e a implementação.

21. Anexo A.2: Políticas relacionadas à IA

O Anexo A.2 estabelece uma estrutura política coerente para a IA, que seja alinhada, aprovada, comunicada e revisada.

21.1 Implementação de controle

- Crie uma política de IA adequada às funções, propósito, contexto, riscos, impactos e compromissos de IA responsável da organização.
- Alinhe-o com as políticas de segurança, privacidade, dados, qualidade, produto, RH, compras, jurídico, registros, segurança do trabalho, acessibilidade, incidentes e comunicação.
- Resolva contradições, como uma meta de inovação que incentive o uso de ferramentas não aprovadas ou uma política de retenção que entre em conflito com a rastreabilidade.
- Aprovar no nível de gestão apropriado; comunicar às pessoas e partes relevantes; vincular aos objetivos, procedimentos, controles, treinamento e aplicação.
- Revisão dentro do prazo e após alterações em leis, tecnologias, negócios, escopo, incidentes, auditorias, reclamações, fornecedores ou sistemas de materiais.

Evidências	Teste
Política de IA aprovada	Verificar o escopo, os compromissos, a autoridade, a data de vigência, a disponibilidade e o proprietário.
Mapa de políticas	Rastrear os requisitos de IA até as políticas relacionadas e os conflitos resolvidos.
Comunicação/treinamento	Exemplos de funções; verificar a compreensão e o fluxo de trabalho prático.
Registro de revisão	Verificar entradas, alterações, decisão, aprovação e acompanhamento.

22. Anexo A.3: Organização Interna

O Anexo A.3 atribui responsabilidades à IA e cria uma forma protegida de relatar preocupações.

22.1 Funções e responsabilidades

- Defina o ciclo de vida e a responsabilidade do sistema de gestão para cada sistema de IA e serviço compartilhado.
- Atribua funções relacionadas a resultados de negócios, IA/modelo, dados, produto, segurança, privacidade, jurídico, impacto, supervisão humana, fornecedor, incidente, auditoria e risco residual.
- Defina autoridade de aprovação e escalonamento, representantes, conflitos, segregação e decisões de emergência.
- Atualize as funções após alterações na organização, no vínculo empregatício, no fornecedor, no sistema, no escopo ou no risco; remova o acesso imediatamente.

22.2 Comunicação de preocupações

- Disponibilizar canais de comunicação internos e externos acessíveis, confidencialidade/anonimato quando apropriado, não retaliação, triagem, investigação, proteção, escalonamento, feedback e registros.
- Aceitar preocupações sobre uso inseguro, parcialidade, direitos, privacidade, segurança, dados, resultados enganosos, IA oculta, comportamento do fornecedor, pressão para burlar controles ou retaliação.
- Avaliar a conscientização, a acessibilidade, a resposta, a recorrência, os casos atrasados e as ações corretivas sem expor os denunciantes.

Os canais de comunicação são mecanismos de controle: um canal é ineficaz se as pessoas não souberem que ele existe, temerem represálias, não puderem relatar danos causados externamente ou nunca receberem evidências de que suas preocupações foram investigadas e corrigidas.

23. Anexo A.4: Recursos para Sistemas de IA

O Anexo A.4 exige visibilidade dos dados, ferramentas, sistemas/computação e pessoas necessárias ao longo do ciclo de vida da IA.

Registro de recursos	Detalhes
Dados	Fonte, proprietário, finalidade, direitos, sensibilidade, pessoas, qualidade, viés, versão, linhagem, retenção, localização
Ferramentas	Algoritmos, estruturas, pacotes, modelos, instruções, avaliação, anotação, orquestração, versões, suporte
Sistema/computação	Nuvem/local/borda, contas, ambientes, armazenamento, rede, GPUs, capacidade, resiliência, energia/meio ambiente
Humano	Função, organização/fornecedor, competência, independência, acesso, carga de trabalho, autoridade de decisão
Dependências	Provedor, subprocessador, API, identidade, monitoramento, filtro de conteúdo, repositório de vetores, processo de negócios

23.1 Fluxo de trabalho de documentação de recursos

- Conecte recursos a sistemas de IA específicos, estágios do ciclo de vida, proprietários, avaliações de risco/impacto, registros de fornecedores, versões e histórico de alterações.
- Conciliar inventários de recursos com código, registros de modelos, catálogos de dados, faturamento de nuvem/API, identidade, rede, compras e entrevistas.
- Identificar recursos não aprovados/ocultos, componentes sem suporte, competências ausentes, limites de capacidade, dependências comuns e impactos ambientais.
- Utilize o registro para fins de reprodutibilidade, resposta a incidentes, avaliação de mudanças, recuperação, desligamento e desativação de fornecedores.

24. Anexo A.5 e ISO/IEC 42005: Avaliação do impacto do sistema de IA

O Anexo A.5 operacionaliza a avaliação de impacto; a norma ISO/IEC 42005:2025 fornece orientações complementares atualizadas.

24.1 Quatro resultados de controle

- Um processo definido e repetível de avaliação de impacto de sistemas de IA, com gatilhos, funções, métodos, integração do ciclo de vida, aprovação e revisão.
- Documentação controlada de avaliações, suposições, evidências, partes afetadas, impactos, medidas de mitigação, decisões e mudanças.
- Avaliação específica dos impactos sobre indivíduos e grupos, incluindo equidade, direitos, privacidade, segurança, saúde, acessibilidade, efeitos financeiros/de emprego, pessoas vulneráveis, supervisão humana e reparação, conforme pertinente.
- Avaliação dos impactos sociais mais amplos, como segurança pública, meio ambiente, economia, cultura, processos democráticos, desinformação, mercado de trabalho, concentração de mercado e uso indevido deliberado, conforme relevantes.

24.2 Verificações de qualidade da avaliação

- As pessoas/grupos afetados são identificados além dos usuários e clientes diretos.
- Os benefícios e os malefícios são avaliados, incluindo a distribuição e as alternativas.
- O método leva em consideração a escala, a duração, a reversibilidade, os efeitos cumulativos e indiretos, a incerteza e o uso indevido previsível.
- O envolvimento das partes interessadas é significativo, acessível, documentado e protegido.
- As medidas de mitigação tornam-se requisitos, testes, notificações, supervisão, monitoramento, reparação e critérios de interrupção inerentes ao processo.
- A versão de avaliação corresponde ao sistema/uso implementado e é atualizada após qualquer alteração substancial.

25. Anexo A.6: Ciclo de Vida do Sistema de IA

O Anexo A.6 relaciona os objetivos do desenvolvimento responsável aos requisitos, projeto, testes, implantação, operação, documentação e registro de eventos.



Responsible-AI objectives become measurable requirements and release evidence

Figura 6. Ciclo de vida de um sistema de IA responsável

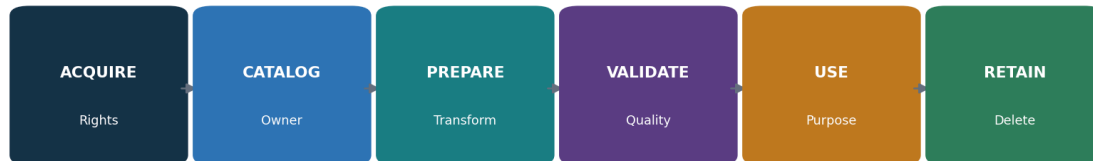
Área do ciclo de vida	Evidências de implementação
Objetivos/processo responsáveis	Equidade, segurança, privacidade, transparência, proteção, robustez e outros objetivos mensuráveis relevantes; procedimento do ciclo de vida
Requisitos/especificações	Finalidade, critérios funcionais e não funcionais, pessoas afetadas, dados, modelo, supervisão humana, limites, obrigações
Registros de projeto/desenvolvimento	Arquitetura, decisões, alternativas, pressupostos, componentes, ameaças, interfaces, proveniência, revisões
Verificação/validação	Métodos, dados de avaliação, avaliadores, limiares, falhas graves, testes de subgrupo/limite/adversariais, limitações
Implantação	Aprovação de versão, ambiente, configuração, informações do usuário, migração, monitoramento, reversão
Operação/monitoramento	Desempenho, desvio, segurança, proteção, impacto, reclamações, alterações, suporte, reparo, atualizações
Documentação técnica/registros	Instruções adequadas ao público-alvo, além de eventos rastreáveis para auditoria, incidentes, decisões e melhorias.

25.1 Mudança e aposentadoria

- Modelo de versão, dados, solicitações, recuperação, ferramentas, código, infraestrutura, políticas, avaliação, aprovações e monitoramento.
- Defina os gatilhos de mudança de material e o escopo da regressão; implemente gradualmente com reversão.
- Desative usuários, identidades, integrações, endpoints, modelos, conjuntos de dados, índices, logs, documentação, contratos e cópias de provedores de acordo com as obrigações; preserve os registros necessários.

26. Anexo A.7: Dados para Sistemas de IA

O Anexo A.7 exige a aquisição, a qualidade, a proveniência e a preparação de dados controlados para o desenvolvimento, o aprimoramento e a operação de IA.



Data evidence must preserve source, transformations, quality, authority, and lifecycle

Figura 7. Cadeia de evidências de dados de IA

26.1 Controles de dados

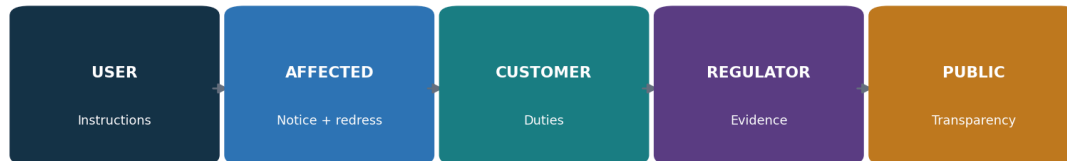
- Defina os requisitos de gerenciamento de dados para privacidade, segurança, representatividade, explicabilidade, proveniência, precisão, integridade, disponibilidade, retenção e exclusão, conforme relevante.
- Aquisição/seleção de documentos: fonte, método, pessoas/população, direitos/licença, finalidade anterior, consentimento/autorização quando aplicável, metadados, data, restrições e viés conhecido.
- Defina critérios e limites de qualidade específicos para cada uso, considerando precisão, integridade, consistência, atualidade, singularidade, validade, representatividade, rótulos e abrangência de subgrupos.
- Preservar a proveniência através da criação, aquisição, transferência, transformação, rotulagem, ampliação, filtragem, versionamento, validação, uso, compartilhamento, correção e exclusão.
- Métodos de preparação do documento, código/ferramenta/versão, parâmetros, pessoas, verificações de qualidade, justificativa, resultados e reprodutibilidade.
- Separe e proteja os conjuntos de dados de treinamento, validação, teste, produção, monitoramento e incidentes; evite o vazamento do conjunto de avaliação.

Evidências de dados	Teste
Conjunto de dados/cartão de dados	Rastrear finalidade, população, campos, origem, direitos, qualidade, limitações, proprietário
Linhagem	Reproduzir transformações de código-fonte para recurso e versão
Resultado de qualidade	Verificar população/amostra completa, regras, falhas, correções e aprovações.
Acesso/retenção	Exemplos de concessões, revisões, remoções, uso, cópias e exclusões.

Evidências de dados	Teste
Viés/representação	Verificar grupos relevantes, histórico, representantes, rótulos, lacunas e mitigação.

27. Anexo A.8: Informações para as partes interessadas

O Anexo A.8 exige informações úteis para usuários e partes interessadas, além de relatórios e comunicação de incidentes.



Different interested parties need different useful and timely information

Figura 8. Informações da parte interessada

27.1 Pacote de informações

- Usuários: finalidade, capacidades, limitações, entrada/saída esperada, uso proibido, verificação, supervisão humana, monitoramento, escalonamento e suporte.
- Pessoas afetadas: que a IA seja usada onde for apropriado, papel na decisão, fatores/limitações importantes, dados e direitos, revisão humana, correção, apelação, reclamação e reparação.
- Clientes/parceiros: responsabilidades, configuração, dados, dependências de controle, evidências, incidentes, alterações, suporte e encerramento.
- Órgãos reguladores/auditores: documentação controlada, escopo, avaliações, controles, resultados de testes, incidentes, alterações, constatações e ações corretivas, conforme necessário.
- Público: transparência proporcional, impactos significativos, governança, informações de segurança, contato e relatórios, quando apropriado.

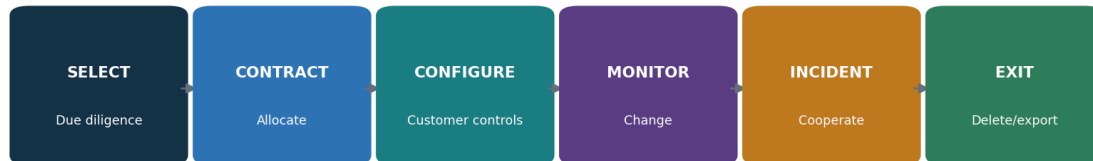
27.2 Comunicação externa e incidentes

- Disponibilize canais acessíveis para relatar erros, danos, preconceitos, problemas de segurança/privacidade, uso indevido, problemas de acessibilidade ou efeitos inesperados.
- Defina triagem, gravidade, investigação, proteção, feedback, correção, reparação, escalonamento, retenção e análise de tendências.

- Defina previamente o público-alvo do incidente, o conteúdo, o responsável/porta-voz, a revisão jurídica, o cronograma, o canal, a acessibilidade, a coordenação, as atualizações e o encerramento.
- Não divulgue informações pessoais ou sensíveis em excesso; não oculte limitações importantes por trás da confidencialidade.

28. Anexos A.9 e A.10: Uso Responsável, Fornecedores e Clientes

O Anexo A.9 rege o uso responsável e a finalidade pretendida; o Anexo A.10 distribui as responsabilidades entre fornecedores, clientes e a cadeia de valor da IA.



Third-party AI risk persists from selection through verified exit

Figura 9. Ciclo de vida da IA de terceiros

28.1 Utilização responsável

- Defina usos, usuários, dados, resultados, decisões, autonomia, verificação, supervisão humana, registro, suporte, incidentes e condições de parada aprovados e proibidos.
- Estabeleça objetivos mensuráveis de uso responsável, vinculados a impactos e riscos relevantes.
- Treinar usuários e supervisores; garantir o cumprimento das normas por meio de identidade, configuração, interfaces, políticas, monitoramento, revisão e consequências.
- Detectar desvios de escopo e exigir reavaliação antes de redirecionar, expandir, incluir novas populações, buscar maior impacto ou integrar novas ferramentas/projetos.

28.2 Terceiros e clientes

- Desenvolvedor/provedor/implementador de mapas, fornecedores de dados/modelos/ferramentas/nuvem, integradores, serviços humanos, clientes, usuários e partes afetadas.
- Atribua responsabilidades por dados, requisitos, testes, configuração, transparência, supervisão humana, segurança, incidentes, monitoramento, mudanças, evidências, direitos, exclusão e encerramento do sistema.
- Realizar due diligence e contratação baseadas em risco; verificar documentação de modelo/sistema, avaliação, garantia de segurança/privacidade, termos de dados, propriedade intelectual, suporte, vulnerabilidades, alterações, subprocessadores, resiliência e portabilidade.

- Monitore as mudanças no modelo/termos/treinamento/retenção/subcontratados/incidentes/descontinuação do fornecedor e reavalie prontamente.
- Defina as obrigações e o suporte ao cliente; não use a responsabilidade do cliente como uma transferência vaga das obrigações do fornecedor.

29. Certificação, ISO/IEC 42006:2025 e Preparação para Auditoria

A certificação avalia o AIMS em relação à norma ISO/IEC 42001 dentro de um escopo definido; a ISO/IEC 42006:2025 reforça os requisitos para os organismos de certificação.

29.1 Caminho de certificação

- Selecione um organismo de certificação competente e verifique sua acreditação/status, esquema de certificação, abrangência geográfica, competência, imparcialidade, escopo, capacidade e contrato.
- Aplicação e planejamento: organização, escopo do AIMS, funções, locais, pessoas, sistemas, complexidade, processos terceirizados, padrões e tempo de auditoria.
- Etapa 1: prontidão, escopo, sistema documentado, contexto, métodos de risco/impacto, Declaração de Aplicabilidade (SoA), auditoria interna, revisão da gestão e preparação para a Etapa 2.
- Etapa 2: implementação e eficácia operacional por meio de entrevistas, amostras, registros, observação e acompanhamento.
- Resolver as não conformidades com correções, causas, ações corretivas e evidências de eficácia, de acordo com as regras do programa.
- Decisão de certificação, certificado, acompanhamento, alterações de escopo, recertificação, suspensão/cancelamento e melhoria contínua.

29.2 Significado da ISO/IEC 42006:2025

- A norma acrescenta requisitos específicos do AIMS para organismos que realizam auditorias e certificações de acordo com a ISO/IEC 42001 e baseia-se na ISO/IEC 17021-1.
- Apoia a competência adequada, processos de auditoria consistentes, imparcialidade, tempo de auditoria e rigor para organizações que desenvolvem, fornecem ou utilizam sistemas de IA.
- A organização deve verificar se a certificação alegada foi emitida ao abrigo de um esquema acreditado relevante e se o âmbito e o estatuto do certificado correspondem à alegação.

Pacote de evidências de auditoria	Exemplos
Fundação	Escopo, contexto, partes, política, fluxograma de processos, funções, inventário
Planejamento	Método/resultados de risco, tratamento, SoA, processo/resultados de impacto, objetivos, mudanças
Suporte/operação	Recursos, competência, comunicação, documentos, ciclo de vida, dados, uso, fornecedores, incidentes
Avaliação/melhoria	Métricas, auditoria interna, análise crítica da gestão, conclusões, ações corretivas, eficácia
Amostras de traços	Registros completos para sistemas de IA representativos de alto/médio/baixo risco e alterações significativas.

29.3 Preparação para auditoria sem teatro

- Mantenha os controles em funcionamento pelo tempo necessário para produzir evidências honestas; não crie registros posteriormente.
- Conciliar escopo, inventário, risco, impacto, SoA, fornecedor, versões do sistema, métricas, auditoria e revisão gerencial.
- Treine os entrevistados para que expliquem seu trabalho real e apresentem evidências, em vez de memorizarem respostas.
- Divulgue com precisão as lacunas, os riscos aceitos, as limitações, os incidentes e as ações corretivas.

30. Ferramentas de código aberto para evidências e garantia de IA do AIMS

As ferramentas de código aberto podem dar suporte à rastreabilidade, avaliação, monitoramento, políticas, privacidade e resultados, mas não determinam a conformidade com a ISO.

Ferramenta	Propósito
MLflow	Registros de rastreamento de experimentos, registro de modelos, linhagem, aprovação e implantação
DVC	Controle de versão para dados, modelos e pipelines.
OpenLineage	Padrão aberto e ferramentas para eventos de linhagem de dados/tarefas
OpenMetadata	Catálogo de dados, linhagem, propriedade, glossário e metadados de qualidade.
Great Expectations	Expectativas automatizadas de qualidade de dados e resultados de validação
Evidently	Relatórios sobre qualidade de dados, desvio, desempenho do modelo e monitoramento
Deepchecks	Testes para dados, modelos de aprendizado de máquina e aplicações de LLM
Giskard	Testes de IA e varredura de vulnerabilidades
Promptfoo	Avaliações de prompt, modelo, RAG e equipe vermelha
Garak	Análise e verificação de vulnerabilidades do LLM
PyRIT	Identificação de riscos e orquestração de testes de intrusão para IA generativa.
Inspect AI	Avaliações de IA reproduzíveis
Presidio	Detecção e desidentificação de informações pessoais
ModelScan	Análise estática de arquivos de modelo serializados
CycloneDX	Formatos e ferramentas para listas de materiais de software, aprendizado de máquina e inteligência artificial.
Open Policy Agent	Decisões de política como código
DefectDojo	Identificação de entrada, deduplicação, propriedade, remediação e reteste.
Langfuse	Rastreamento, gerenciamento imediato e avaliação de LLM de código aberto

Governança de ferramentas: Utilize apenas sistemas, modelos, contas, repositórios e dados autorizados. Comece com ambientes isolados e dados sintéticos. Proteja credenciais, prompts, saídas, rastreamentos, informações pessoais e resultados. Registre versões e valide os resultados automatizados.

30.1 MLflow

Finalidade: Rastreamento de experimentos, registro de modelos, linhagem, aprovação e registros de implantação. Projeto oficial: [MLflow](#)

Início rápido e seguro: Crie um projeto local; registre parâmetros, referência do conjunto de dados, métricas, artefatos, proprietário e aprovação; registre apenas um modelo testado; restrinja as alterações no registro.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.2 DVC

Finalidade: Controle de versão para dados, modelos e pipelines. Projeto oficial: [DVC](#)

Início rápido e seguro: Utilize um conjunto de dados sintéticos em um repositório de treinamento; controle as versões dos dados e dos estágios do pipeline; reproduza uma execução; proteja o armazenamento remoto e as credenciais.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.3 OpenLineage

Objetivo: Padrão aberto e ferramentas para eventos de linhagem de dados/tarefas. Projeto oficial: [OpenLineage](#)

Início rápido e seguro: Instrumente um pequeno pipeline de laboratório; registre os relacionamentos entre conjuntos de dados e tarefas; verifique a integridade dos eventos; proteja metadados confidenciais.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.4 OpenMetadata

Finalidade: Catálogo de dados, linhagem, propriedade, glossário e metadados de qualidade. Projeto oficial: [OpenMetadata](#)

Início rápido e seguro: Implante uma instância de laboratório; catalogue conjuntos de dados sintéticos; atribua proprietários/classificação; documente a linhagem e a retenção; restrinja os conectores.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.5 Great Expectations

Objetivo: Expectativas automatizadas de qualidade de dados e resultados de validação. Projeto oficial: [Great Expectations](#)

Início rápido e seguro: Defina a precisão, a integridade, o intervalo e as expectativas nulas para dados sintéticos; execute a validação; preserve o conjunto de testes/versão/resultados e exceções.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.6 Evidently

Objetivo: Relatórios de qualidade de dados, deriva, desempenho do modelo e monitoramento. Projeto oficial: [Evidently](#)

Início rápido e seguro: Crie conjuntos de dados sintéticos de referência e atuais; execute um relatório; defina limites de ação; investigue antes de re-treinar ou reverter.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.7 Deepchecks

Objetivo: Testar dados, modelos de aprendizado de máquina e aplicações de aprendizado de máquina. Projeto oficial: [Deepchecks](#)

Início rápido e seguro: Execute um conjunto de testes direcionado a dados de laboratório aprovados; revise a relevância e os falsos positivos; registre as exceções; execute novamente após a correção.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.8 Giskard

Objetivo: Testes de IA e varredura de vulnerabilidades. Projeto oficial: [Giskard](#)

Início rápido e seguro: Conecte apenas um modelo de teste e conjunto de dados aprovados; selecione os testes relevantes; valide as falhas manualmente; guarde o relatório e realize um novo teste de correção.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.9 Promptfoo

Objetivo: Avaliações de prompts, modelos, RAG e equipes vermelhas. Projeto oficial: [Promptfoo](#)

Início rápido e seguro: Crie um conjunto de testes YAML versionados com casos sintéticos e comportamento esperado; execute localmente; revise as falhas; mantenha a configuração e os resultados.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.10 Garak

Objetivo: Varredura e sondagem de vulnerabilidades LLM. Projeto oficial: [Garak](#)

Início rápido e seguro: Utilize um modelo de laboratório isolado e um conjunto limitado de sondas aprovadas; limite as solicitações e os custos; proteja os resultados; valide cada descoberta.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.11 PyRIT

Objetivo: Identificação de riscos e orquestração de ataques de equipe vermelha para IA generativa.

Projeto oficial: [PyRIT](#)

Início rápido e seguro: Defina regras de laboratório por escrito; utilize objetivos inofensivos e dados sintéticos; estabeleça limites de solicitação/tempo/custo; proteja transcrições e resultados.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.12 Inspect AI

Objetivo: Avaliações de IA reproduzíveis. Projeto oficial: [Inspect AI](#)

Início rápido e seguro: Defina uma tarefa, um conjunto de dados, um solucionador, um avaliador e uma regra de aceitação; fixe as versões; execute um modelo aprovado; mantenha registros e limitações.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.13 Presidio

Finalidade: Detecção e desidentificação de informações pessoais. Projeto oficial: [Presidio](#)

Início rápido e seguro: teste com exemplos sintéticos; configure os reconhecedores para idioma/contexto; inspecione falsos positivos e falhas; proteja a saída do analisador.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.14 ModelScan

Finalidade: Leitura estática de arquivos de modelos serializados. Projeto oficial: [ModelScan](#)

Início rápido e seguro: Analise um artefato em quarentena; verifique a origem e o hash; investigue os avisos; nunca carregue um modelo não confiável apenas para testá-lo.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.15 CycloneDX

Objetivo: Formatos e ferramentas para listas de materiais de software, aprendizado de máquina e inteligência artificial. Projeto oficial: [CycloneDX](#)

Início rápido e seguro: gere uma lista de materiais para um repositório de laboratório; valide componentes e versões; vincule as descobertas aos registros de proprietários e fornecedores.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.16 Open Policy Agent

Objetivo: Decisões baseadas em políticas como código. Projeto oficial: [Open Policy Agent](#).

Início rápido e seguro: Elabore uma pequena regra de laboratório para modelo/dados/uso aprovados; teste os casos de permissão, negação e dados ausentes; revise as alterações por pares; mantenha a autoridade para exceções humanas.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.17 DefectDojo

Objetivo: Identificar problemas de entrada, desduplicação, responsabilidade, correção e reteste.

Projeto oficial: [DefectDojo](#)

Início rápido e seguro: Importe resultados de laboratório seguros; valide duplicatas e gravidade; atribua responsável/data; anexe evidências; feche somente após novo teste.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

30.18 Langfuse

Objetivo: Rastreamento, gerenciamento de prazos e avaliação de projetos de mestrado em direito (LLM) de código aberto. Projeto oficial: [Langfuse](#)

Início rápido e seguro: Utilize um laboratório aprovado; oculte campos sensíveis; rastreie um fluxo de trabalho; restrinja o acesso/retenção; conecte os rastreamentos aos registros de avaliação e incidentes.

Evidências do AIMS: autoridade/âmbito, versões do sistema/modelo/dados, identidade, ferramenta/versão/configuração, critérios/limiares, data, população de origem, resultado, validação humana, limitações, descoberta, responsável/ação, aprovação e reteste.

31. Manual do Gerente e do Analista Júnior, Laboratório e Entrevistas

Os gestores mantêm os objetivos do Sistema de Gestão de Incentivos (AIMS) vinculados a resultados reais; os analistas juniores criam inventários confiáveis, documentos de trabalho, conclusões e evidências de melhoria.



Junior analysts demonstrate competence through practical, traceable AIMS work

Figura 10. Trajetória de analista júnior do AIMS

31.1 Perguntas do gerente

Pergunta	Evidências robustas	Bandeira vermelha
O que está incluído no escopo?	Conciliação do inventário de IA, limites de organização/função/sistema/dados/fornecedor	O escopo de marketing é mais amplo do que o certificado.
Quem pode decidir?	Autoridade nomeada para negócios, sistemas, dados, impacto, risco, fornecedores, incidentes e auditorias.	A equipe de IA aceita sozinha os riscos comerciais/jurídicos.
Que danos são possíveis?	Avaliações atuais de risco e impacto com as pessoas afetadas e alternativas.	Considera-se apenas a precisão do modelo.
O que comprova a prontidão?	Avaliação versionada semelhante à de produção, limites, falhas, supervisão, reversão.	Somente demonstração ou política do fornecedor
O que altera o risco?	Lista de gatilhos, monitoramento, notificação ao provedor, regressão, reavaliação	Atualizações automáticas sem revisão
O AIMS está melhorando?	Objetivos, auditoria, reclamações/incidentes, causas raízes, ações eficazes	O certificado é a única medida de sucesso.

31.2 Trabalho de analista júnior

- Manter o inventário de IA, escopo, partes interessadas, obrigações, registros de risco/impacto, Declaração de Aplicabilidade (SoA), registros de fornecedores, objetivos, evidências e ações.
- Mapear cláusulas/controles para processos e evidências reais do sistema; conciliar populações e versões.

- Controle de documentos de teste, competência, pontos de controle do ciclo de vida, linhagem/qualidade de dados, avaliação, uso responsável, mudança de fornecedor, monitoramento, incidentes e ação corretiva.
- Redigir conclusões objetivas e resumos para a gerência; acompanhar as correções e a eficácia dos testes.
- Apoiar auditorias internas e revisões de gestão sem tomar decisões reservadas aos proprietários ou auditores.

Regra do laboratório de portfólio: Utilize uma organização fictícia, dados sintéticos e modelos de teste locais ou aprovados. Nunca afirme que o projeto é certificado, auditado por um órgão acreditado ou baseado em evidências confidenciais do empregador.

31.3 Laboratório fictício

- Crie uma empresa fictícia com 100 funcionários que desenvolve um assistente de suporte ao cliente baseado em características (RAG) e utiliza um assistente de redação de RH adquirido, porém sem capacidade de tomar decisões de contratação.
- Defina o contexto do AIMS, as partes interessadas, as funções, o escopo, a política, o fluxograma de processos, o inventário de IA, as obrigações e o roteiro de implementação.
- Crie um método de risco, seis cenários de risco, um plano de tratamento, um SoA de 38 controles e duas avaliações de impacto usando os conceitos da ISO/IEC 42005.
- Criar registros de recursos, conjuntos de dados, modelos/sistemas, fornecedores, informações do usuário, comunicação, competências e controle de documentos.
- Realizar avaliações sintéticas usando duas ferramentas de código aberto; manter versões, limites, falhas, correções e reteste.
- Criar objetivos/painel de controle, plano de auditoria interna e cinco papéis de trabalho, duas constatações, ações corretivas, pacote de revisão gerencial e relatório de prontidão para certificação.
- Publique apenas evidências fictícias higienizadas e uma declaração honesta de limitações.

31.4 Plano de trinta dias

Dias	Foco	Entregável
1–3	Padrão, AIMS, PDCA	Mapa de cláusulas e glossário
4–6	Contexto, partes, âmbito	Âmbito de aplicação e registro de partes interessadas
7–9	Liderança e planejamento	Política, RACI, objetivos
10–12	Risco e tratamento	Método, registro, plano, SoA
13–15	Avaliação de impacto	Dois documentos de trabalho sobre o impacto
16–18	Suporte e documentos	Competência, comunicação, controle de documentos
19–21	Ciclo de vida, dados, uso, fornecedores	Cinco documentos de controle
22–24	Medição e ferramentas	Painel de controle e evidências de avaliação
25–27	Auditoria e ação corretiva	Relatório de auditoria, conclusões, plano de eficácia
28–30	Análise e entrevista de gestão	Pacote de revisão, memorando de prontidão, histórias STAR

31.5 O que é a ISO/IEC 42001?

Uma norma de sistema de gestão certificável para organizações que desenvolvem, fornecem ou utilizam sistemas de IA. Ela estabelece requisitos para governança responsável, gestão de riscos, impacto, operação, avaliação e melhoria.

31.6 O que é um AIMS?

As políticas, os objetivos, os processos, as funções, os controles e os registros inter-relacionados da organização para gerenciar a IA de forma responsável dentro de um escopo definido.

31.7 Todos os controles do Anexo A são obrigatórios?

São controles de referência considerados no tratamento de riscos. A organização documenta a aplicabilidade e a implementação na Declaração de Aplicabilidade e pode adicionar outros controles.

31.8 Avaliação de risco versus avaliação de impacto?

A avaliação de riscos gerencia a incerteza que afeta os objetivos. A avaliação do impacto de sistemas de IA concentra-se nos efeitos sobre indivíduos, grupos e sociedade. Elas trocam resultados, mas não são idênticas.

31.9 O que é a Declaração de Aplicabilidade?

Um registro controlado explicando quais controles do Anexo A e controles adicionais se aplicam, por quê, como são implementados, seu status, evidências, lacunas e revisão.

31.10 Estágio 1 versus Estágio 2?

A Etapa 1 avalia o escopo, o sistema documentado, a prontidão e o planejamento. A Etapa 2 avalia a implementação e a eficácia operacional por meio de evidências e amostragem.

31.11 O que é uma não conformidade?

Um requisito não foi cumprido. A constatação deve identificar os critérios, as evidências objetivas e a lacuna, sem prescrever a solução a ser encontrada pela entidade auditada.

31.12 Como as ferramentas comprovam a conformidade?

Não. As ferramentas produzem evidências que devem ser delimitadas, validadas, interpretadas em relação aos requisitos, conectadas aos controles e revisadas por pessoas competentes.

31.13 Como testar uma ação corretiva?

Verificar a correção, a ação na causa raiz, a aplicação em condições semelhantes e as evidências de que o risco de recorrência foi reduzido após a intervenção necessária.

31.14 O que caracteriza um bom analista júnior?

Escopo preciso, evidências rigorosas, compreensão das cláusulas, redação clara, respeito pelas pessoas afetadas, incerteza honesta, uso seguro das ferramentas e acompanhamento confiável.

32. Modelos, Glossário, Índice e Referências Oficiais

Estruturas de trabalho reutilizáveis e referências confiáveis apoiam a implementação e auditoria consistentes do AIMS.

32.1 Registro de escopo e contexto do AIMS

Campo	Entrada
Organizações/unidades de negócio/localizações	
Papel da IA, produtos/serviços/processos	
Sistemas/modelos/dados/ambientes de IA	
questões internas/externas	
Partes interessadas e requisitos	
Obrigações legais/contratuais	
Limites, interfaces, dependências	
Processos terceirizados/compartilhados	
Exclusões e justificativas	
Gatilhos de aprovação e revisão de escopo	

32.2 Registro de risco e tratamento da IA

Campo	Entrada
Sistema/uso/versão/proprietário	
Cenário, parte afetada, consequência	
Probabilidade/impacto/incerteza/evidência	
Controles existentes e eficácia	
Avaliação/tolerância ao risco	
Opção de tratamento/controle	
Anexo A/mapeamento de controle adicional	
Proprietário/recurso/data/medida	
risco residual/aprovador/condições	
Monitoramento/revisão/reteste	

32.3 Declaração de Aplicabilidade

Campo	Entrada
Referência/título de controle	
Aplicabilidade e justificativa	
Riscos/impactos/obrigações relacionados	
Implementação e proprietário	
Status e data prevista	
Evidências e resultados dos testes	
Dependências entre fornecedores e clientes	
Risco residual/excepcional/de lacuna	
Última/próxima avaliação	
Histórico de alterações/aprovação	

32.4 Avaliação do impacto do sistema de IA

Campo	Entrada
Finalidade, uso, pessoas afetadas, alternativas	
Sistema/dados/modelo/fornecedor/contexto	
Benefícios e impactos adversos	

Campo	Entrada
Efeitos individuais/grupais/sociais	
Probabilidade/gravidade/escala/duração	
Reversibilidade/distribuição/incerteza	
Envolvimento das partes interessadas	
Mitigação/supervisão/transparência/reparação	
Decisão/autoridade/condições	
Monitoramento/gatilhos/revisão	

32.5 Documento de trabalho de auditoria interna

Campo	Entrada
Crítérios/âmbito/objetivo	
Processo/sistema/versão/período	
População/amostra/justificativa	
Evidências/fontes/confiabilidade	
Resultado do teste/esperado	
Resultados observados/exceções	
Conclusão/não conformidade	
Indicação de risco/impacto/causa	
Correção/ação corretiva	
Eficácia/acompanhamento/conclusão	

32.6 Registro de revisão gerencial

Campo	Entrada
Status da ação anterior	
Alterações de contexto/participação	
Objetivos/tendências de desempenho	
Risco/impacto/tratamento/SoA	
Auditoria/não conformidade/ação corretiva	
Incidentes/reclamações/preocupações/reclamações	
Alterações de fornecedores/jurídicas/de sistema	
Recursos/competências	
Decisões/ações/proprietários/datas	
Eficácia/acompanhamento	

32.7 Glossário

Prazo	Significado
AIMS	Sistema de gestão de inteligência artificial.
avaliação do impacto do sistema de IA	Avaliação estruturada dos potenciais efeitos sobre indivíduos, grupos e sociedade.
Anexo A	Objetivos e controles de referência da norma ISO/IEC 42001.
Anexo B	Orientações de implementação para os controles do Anexo A.
Certificação	Atestado de terceiros comprovando que o AIMS definido está em conformidade com os requisitos especificados.
Conformidade	Cumprimento de um requisito.
Controlar	Medida que mantém ou modifica o risco.
Correção	Ação para eliminar uma não conformidade detectada.
Ação corretiva	Ação para eliminar a causa e prevenir a recorrência.
Informações documentadas	Informações que a organização controla e mantém, além do meio pelo qual ela é utilizada.
Parte interessada	Pessoa ou organização que pode afetar, ser afetada por ou perceber-se afetada por uma decisão/atividade.
Auditoria interna	Processo sistemático, independente e objetivo para avaliar evidências em relação a critérios.
Não conformidade	Não cumprimento de um requisito.

Prazo	Significado
Objetivo	Resultado a ser alcançado.
risco residual	Riscos que permanecem após o tratamento.
Responsável pelo risco	Pessoa/entidade com responsabilidade e autoridade para gerir o risco.
SoA	Declaração de Aplicabilidade.
Etapa 1	Etapa de preparação para certificação e auditoria do sistema documentado.
Etapa 2	Etapa de implementação da certificação e auditoria de eficácia operacional.
Alta administração	Pessoa/grupo que dirige e controla a organização no nível mais alto dentro do seu âmbito de atuação.

32.8 Índice de assuntos

Assunto	Capítulo
Controles do Anexo A	20–28
Auditoria	17, 29
Certificação	29
Contexto/escopo	3–4
Ação corretiva	19
Dados	23, 26
Documentos	13
Avaliação de impacto	9, 24
Partes interessadas	4, 27
Liderança/política	5, 21
Vida útil	14–15, 25
Gerente/analista júnior	31
Medição/revisão	16–18
Objetivos/mudança	10
Recursos/competências	11–12, 23
Risco/tratamento/SoA	6–8
Fornecedores/uso	28
Ferramentas	30

32.9 Referências oficiais

- [Página oficial da ISO/IEC 42001:2023](#)
- [Explicação da norma ISO 42001](#)
- [Plataforma de navegação online ISO/IEC 42001](#)
- [Avaliação do impacto do sistema de IA segundo a norma ISO/IEC 42005:2025](#)
- [organismos de certificação ISO/IEC 42006:2025](#)
- [Diretrizes de auditoria ISO 19011:2026](#)
- [ISO/IEC 23894:2023 Gestão de riscos de IA](#)
- [ISO/IEC 22989:2022 Conceitos e terminologia de IA](#)
- [Estrutura do sistema de ML ISO/IEC 23053:2022](#)
- [Implicações de governança da IA segundo a norma ISO/IEC 38507:2022](#)
- [Catálogo ISO/IEC JTC 1/SC 42](#)
- [normas ISO de sistemas de gestão](#)
- [Pesquisa de Certificados da IAF](#)
- [Estrutura de Gestão de Riscos de IA do NIST](#)
- [Princípios de IA da OCDE](#)
- [Página oficial da política da Lei de IA da UE](#)

Lembrete final: Utilize uma cópia autorizada da norma. As normas ISO, os esquemas de certificação, a acreditação, as leis, os sistemas de IA, os fornecedores, os riscos, as ferramentas e as orientações oficiais estão sujeitos a alterações. Verifique a fonte atual, a edição exata, o escopo/status do certificado, a versão do sistema e as informações organizacionais antes da implementação, auditoria, certificação ou declarações públicas.